Information Security

Mock 4

Academic Year 2026–2027

Duration: 1 h 30

Instructions. Answer all questions. Responses must be *concise* and every claim must be *justified*. Calculators and external material are not permitted.

Part I – Web Privacy and Data Protection

A software firm runs a hosted analytics dashboard reachable at the host `metrics.example`. The service has the following characteristics:

- Customers may build custom dashboard widgets by uploading their own HTML and JavaScript, which the platform then serves from `http://metrics.example/widgets/<customer>/`. For instance, a customer named Alice serves a widget from `http://metrics.example/widgets/alice/`. The same content is also reachable over HTTPS.
- The main application, where account and billing settings live, is at `http://metrics.example/app/`. A customer signs in there with an email address and password; on success the server issues a session cookie that keeps the customer authenticated.
- The server is misconfigured and accepts connections over both HTTP and HTTPS.

Inspection of the session cookie reveals the following attributes:

Attribute	Value
Name	`auth`
Value	(random authentication token)
Path	`/`
Domain	`metrics.example`
SameSite	`Lax`
Secure	set

The cookie does *not* carry the `HttpOnly` attribute.

Q1. Bob authenticates to the application over HTTPS, so his browser stores the `auth` cookie. He then follows an internal link that is served over plain HTTP. Throughout, the attacker Eve passively monitors Bob's network traffic. Can Eve recover the value of the `auth` cookie? State your reasoning.

Q2. Alice may publish arbitrary HTML and JavaScript at `http://metrics.example/widgets/alice/` (also reachable over HTTPS), but she holds no further privileges: she cannot modify the application and cannot read its logs. Determine whether Alice is able to obtain Bob's `auth` cookie. If she is, describe concretely how she would construct her widget to capture it; if she is not, explain what prevents her.

Q3. The firm's administrators weigh several changes to the way the cookie is issued.

(a) Suppose the administrators additionally set the `HttpOnly` attribute on the cookie. State, with reasons, how this affects your answers to Questions 1 and 2.

(b) Suppose instead that the administrators remove the `Secure` attribute (and `HttpOnly` is still not set). State, with reasons, how this affects your answers to Questions 1 and 2.

Q4. For the two independent scenarios below, return to Alice's situation in Question 2 and disregard the attribute changes considered in Question 3.

(a) The application is moved to the host `app.metrics.example`, and the cookie's `Domain` attribute is set to `app.metrics.example`, while Alice's widgets remain at `metrics.example/widgets/alice/`. Does your answer to Question 2 still hold? Explain.

(b) Independently, suppose the cookie's `SameSite` attribute is tightened from `Lax` to `Strict`, with all other attributes as originally given. Does this prevent the attack you considered in Question 2? Explain.

Part II – Cryptography

Scenario. Alice is building cryptographic tools for a small firm. The adversary Eve can observe all network traffic, store the messages she sees, and on occasion inject or replace messages of her own.

A. Block-cipher internals and key establishment

Alice adopts AES-128 as the firm's encryption scheme.

Q1. AES carries out its arithmetic in the finite field $\mathrm{GF}(2^8)$, with multiplication performed modulo the irreducible polynomial $x^8+x^4+x^3+x+1$ (that is, `0x11B`). Compute the product of the two bytes `6E` and `25` (given in hexadecimal) in this field. Show every intermediate shift-and-reduce step of the computation.

Q2. Bob has published an authentic public key, but Alice and Bob share no secret key in advance. Describe a method by which Alice can establish a fresh shared symmetric key with Bob, using his public key, so that the two can then encrypt their documents efficiently. Give the sequence of steps.

B. Analysis of a sealed-bid auction protocol

Alice and Bob are the only two participants in a sealed-bid auction held over an insecure network, with no trusted third party. Each wishes to submit a secret monetary bid; the higher bid wins. The design goals are that neither party can learn the other's bid before committing to its own, and that neither can alter its bid after learning the other's.

Q3. Consider the naive protocol in which each party simply sends its bid, in the clear, to the other. Identify the opportunities for cheating that this protocol permits.

Q4. To address this, Alice proposes the following scheme:

- Each party encrypts its own bid under a secret key it chooses (Alice uses K_A, Bob uses K_B) and sends the resulting ciphertext.
- Once both ciphertexts have been exchanged, each party reveals its key, and the other decrypts the ciphertext and learns the bid.

(a) Identify any remaining opportunities for cheating, and justify your answer.

(b) Could the symmetric cipher be replaced by a public-key encryption scheme? Would such a substitution make the protocol secure? Justify your answer.

Q5. Alice and Bob now consider using a cryptographic hash function H.

(a) Design a protocol, based on H, that meets the two design goals stated above. Specify the messages exchanged and the verification each party performs.

(b) Define the *collision-resistance* property of a cryptographic hash function. What happens to your protocol if H fails to be collision-resistant? Explain.

(c) Define the *preimage-resistance* property of a cryptographic hash function. What happens to your protocol if H fails to be preimage-resistant? Explain.

— End of questions —